TP 3.2 : Attaque d'un système Windows et extraction d'identifiants.

Le TP se déroule entre deux environnements la machine d'attaque (**Kali Linux**) et la machine cible (**Windows**).

INTRODUCTION

L'objectif de ce TP est de démontrer qu'une compromission de système ne nécessite pas toujours une vulnérabilité technique complexe. Nous avons ici reproduit un scénario où l'attaquant utilise l'observation du réseau et la faiblesse des politiques de mots de passe pour obtenir un accès total à une machine Windows cible

Étape 1 : Vérification de la connectivité

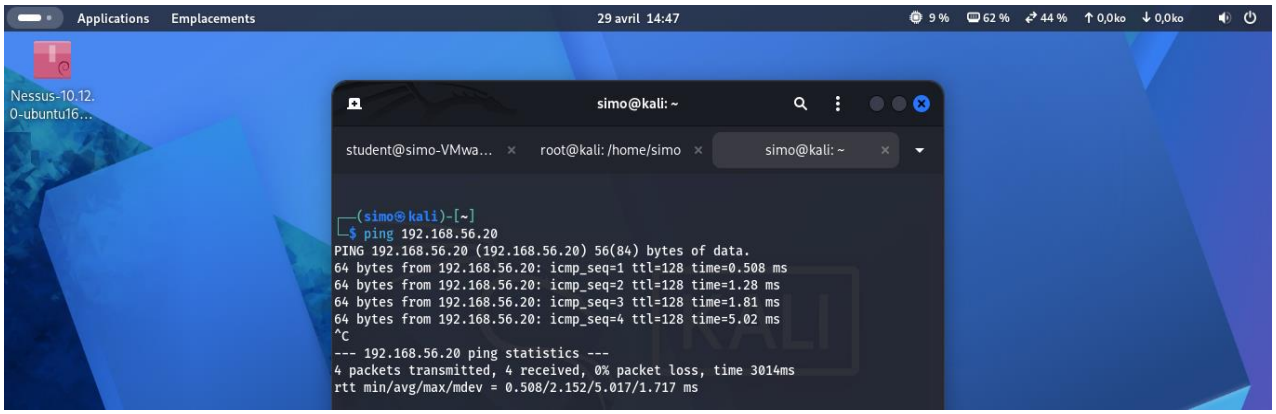
Avant toute chose nous allons nous rassurer que les deux machines communiquent.

Ip windows 192.168.56.20

Ip kali 192.168.56.30

- **Machine : Kali Linux**

ping 192.168.56.20

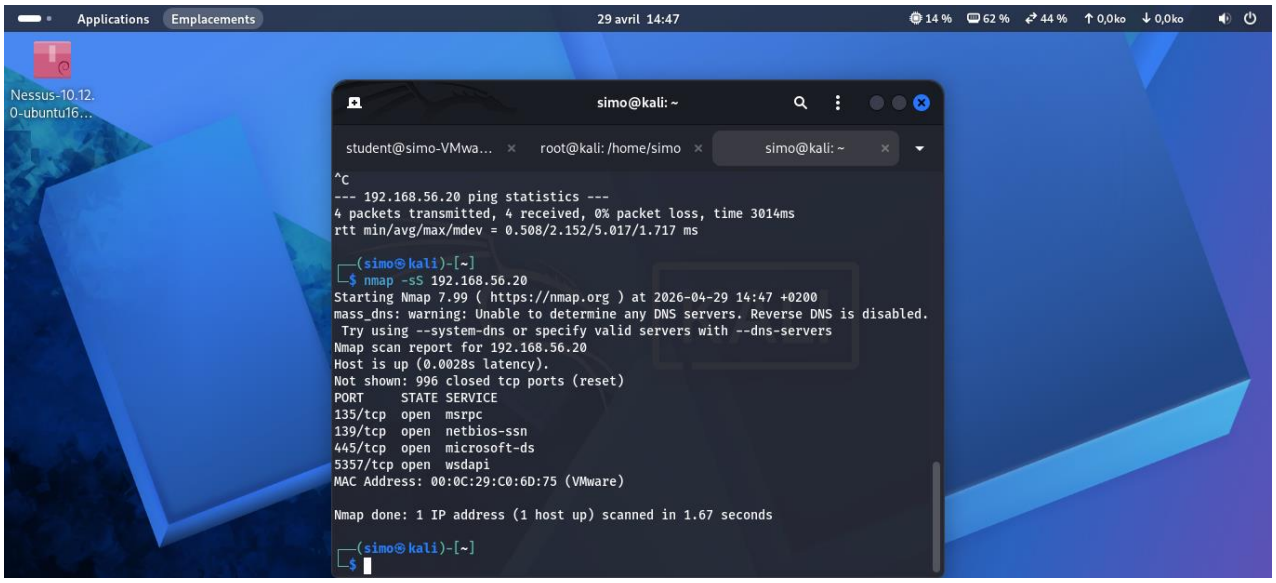


Étape 2 : Identification des services (Scan de ports)

Détectons si le service de partage de fichiers (SMB) est ouvert. Une fois la connectivité réseau confirmée, l'étape suivante consiste à explorer la machine cible pour découvrir les services actifs. Cette phase de reconnaissance est cruciale pour identifier les vecteurs d'attaque potentiels

- **Machine : Kali Linux**
  Un scan de ports a été effectué pour identifier les vecteurs d'entrée :

  Commande utiliser **nmap -sS 192.168.56.20**



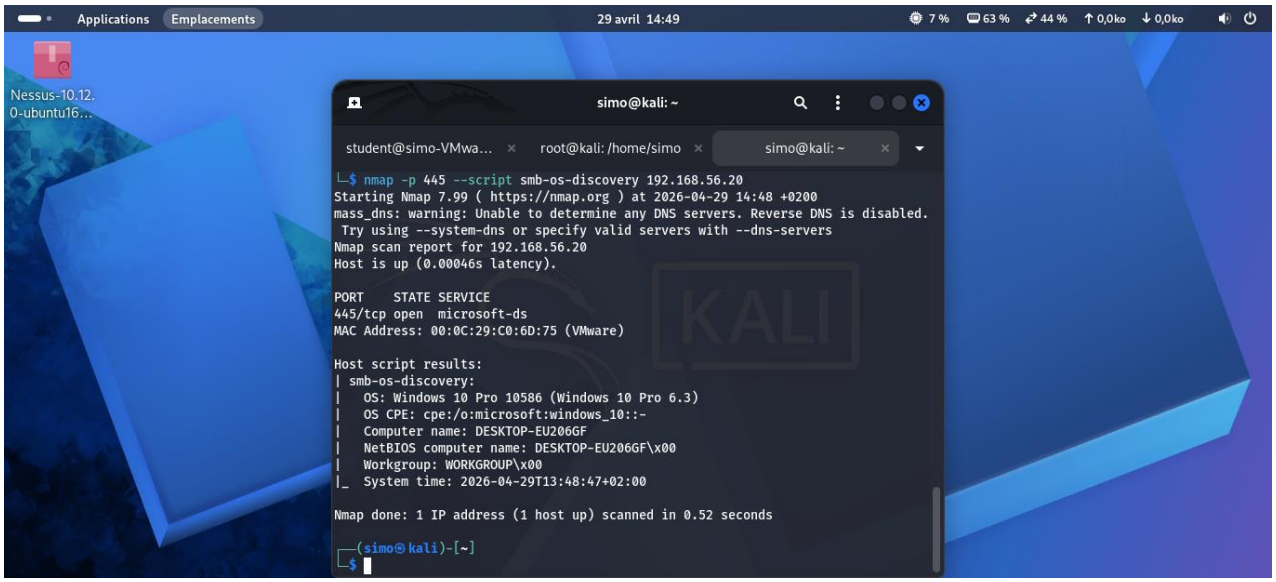
Observation le port 445(SMB) est ouvert. Ce service est souvent utilisé pour partager les fichiers et constitue une surface d'attaque privilégiée.

Étape 3 : Énumération et reconnaissance SMB

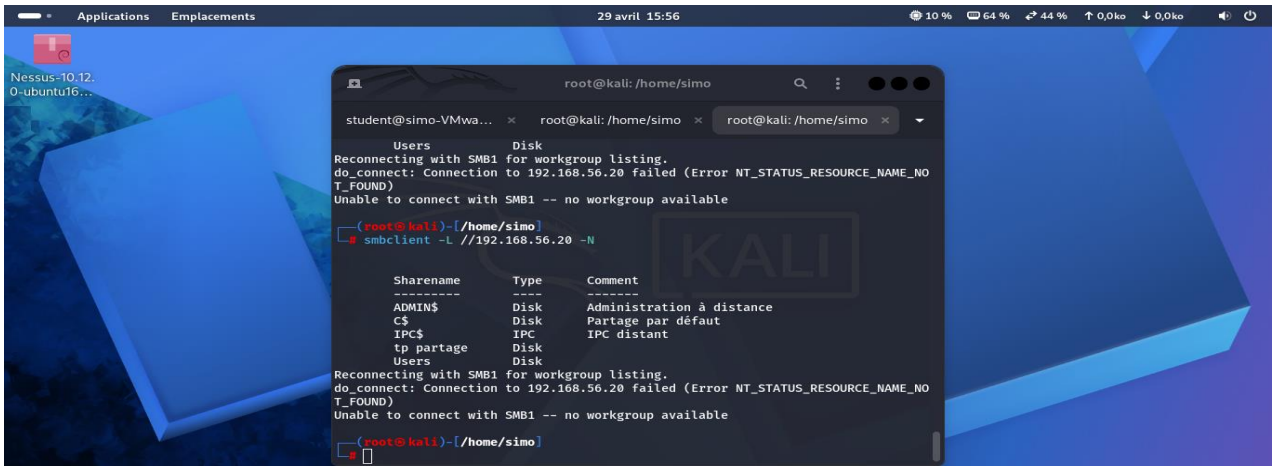
Obtenir des informations sur le système et lister les partages sans mot de passe.

- **Machine : Kali Linux**

Identifions la version de l'OS via SMB avec la commande : **nmap -p 445 --script smb-os-discovery 192.168.56.20**



Listons les partages disponibles (accès anonyme) smbclient -L //192.168.56.20 –N



Étape 4 : Préparation de la cible (Simulation de mot de passe faible)

Cible : Créer manuellement un utilisateur vulnérable pour tester l'attaque.

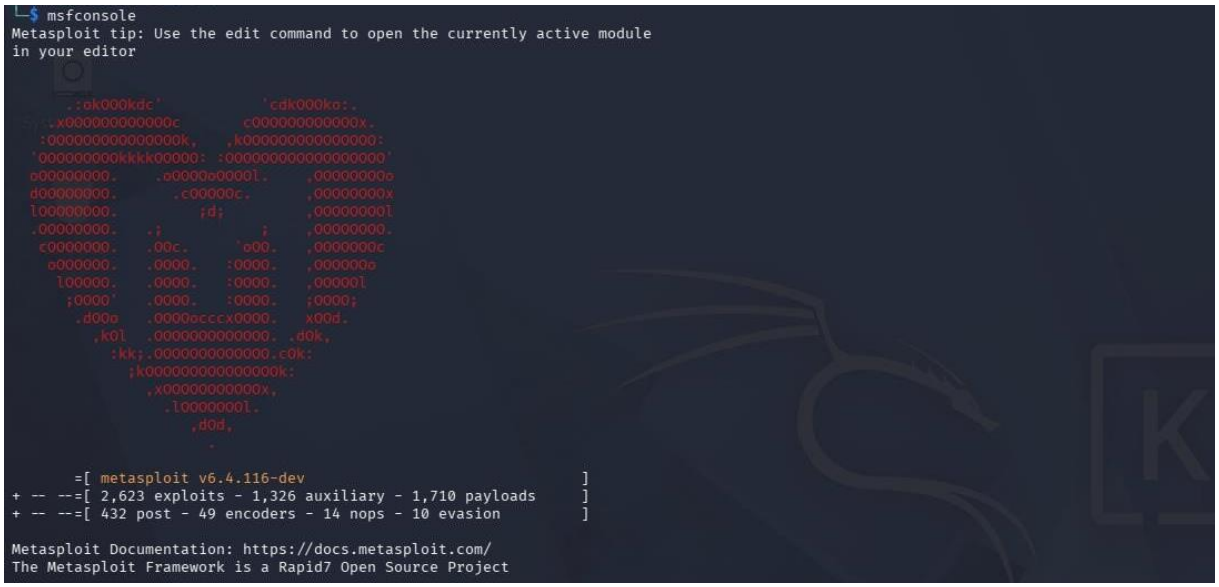
- **Machine : Windows (PowerShell en tant qu'administrateur)**

Étape 5 : Test d'authentification avec Metasploit

Vérifier si les identifiants créés permettent une connexion.

- **Machine : Kali Linux**

Msfconsole

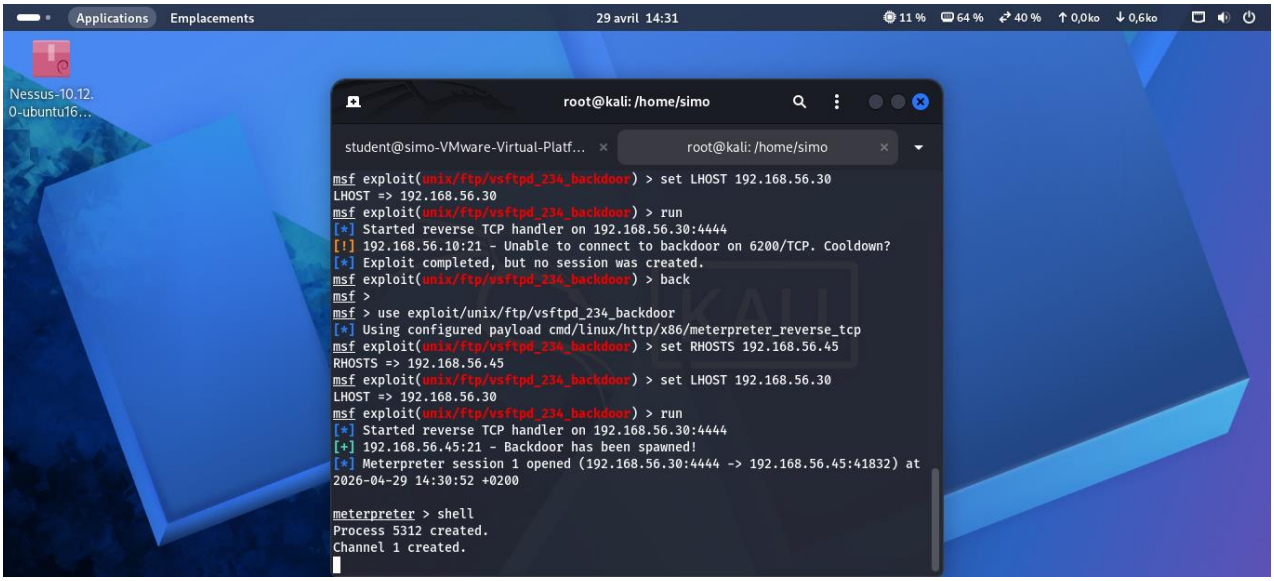


Dans Metasploit :

Après avoir identifié le service SMB ouvert sur le port 445, nous utilisons le framework Metaspoit pour vérifier si les identifiants sont vulnérable. Cette phase simule une attaque par force brute ou par test de dictionnaire sur un compte connu. Nous avons utilisé les commandes suivantes :

Pour le Chargement du scanner : **use auxiliaire/scanner/smb/smb_login**

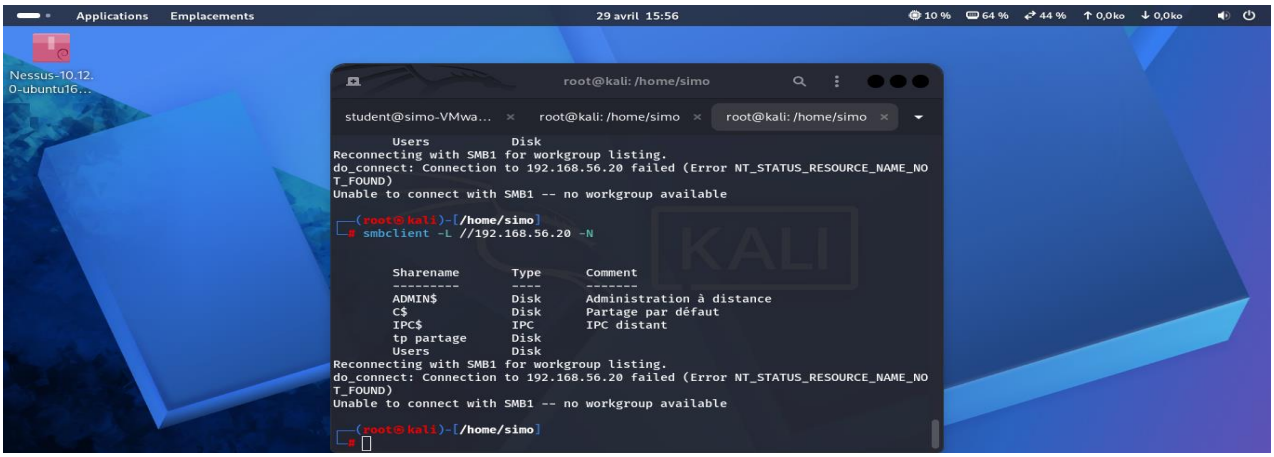
Cibler le scan : **set RHOSTS 192.168.56.20**



Étape 6 : Compromission réelle (Ouverture d'une session distante)

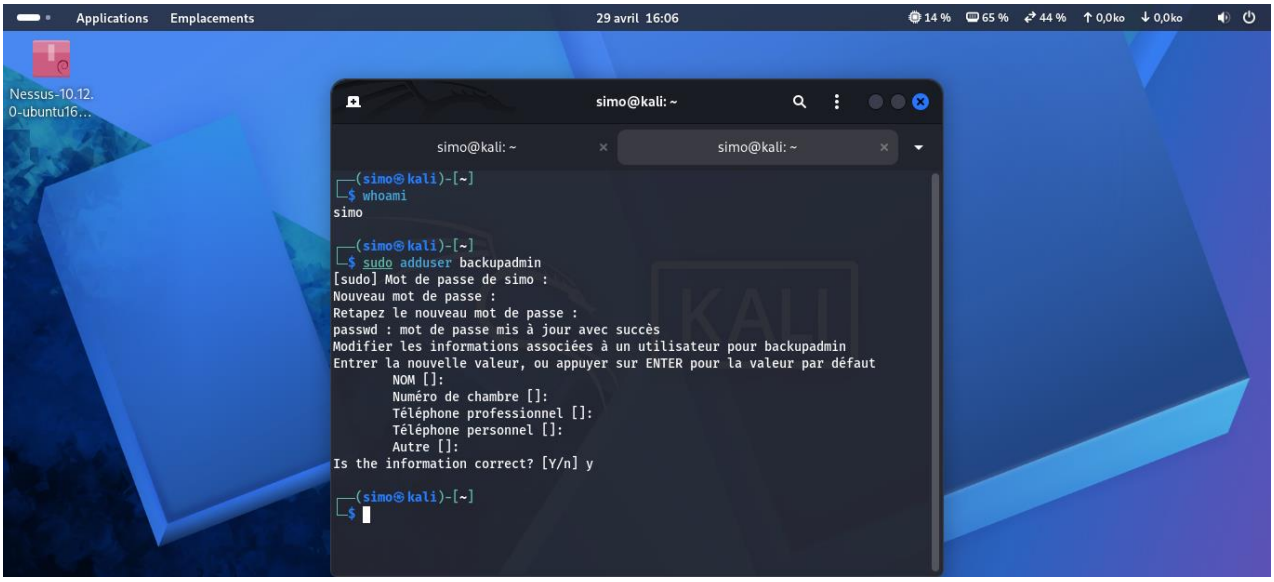
Prendre le contrôle total de la machine via un shell Meterpreter.

- **Machine : Kali Linux (toujours dans Metasploit)** Nous avons executer les commandes suivantes :



Une fois la session ouverte, vérifions identité :

Getuid



Étape 7 : Extraction d'informations (Post-Exploitation)

Récupérer les empreintes (hashes) des mots de passe de tous les utilisateurs.

- **Machine : Kali Linux (dans la session Meterpreter)**

  Shell pour ouvrir une invite de commande windows classique

Conclusion

Ce TP démontre qu’une hygiène de sécurité défaillante est tout aussi dangereuse qu’une faille logicielle.la visibilité d’un service est la première étape vers sa compromission